

アカウント管理ガイドライン

第1版 2026年4月1日 発行

株式会社ブリックスマート セキュリティ管理部

第1章 目的

本ガイドラインは、ECサイト「ブリックスマート」における顧客アカウントの管理、特に不正アカウントの検知・凍結・解除に関する手順を定める。

第2章 アカウントリスク評価

2.1 リスクスコアの算出方法

リスクスコアは以下の重み付けで算出される（システムが自動計算）。

行動	重み	説明
ログイン失敗	×1	単純なパスワード間違いも含む
ブルートフォース関連イベント	×3	短時間での連続ログイン試行
BOT活動	×5	自動化ツールによるアクセスパターン
不正購入試行	×10	不正なクレジットカード利用等

2.2 リスクレベルの定義

リスクレベル	スコア	自動アクション	手動対応
Critical	50以上	アカウント自動ロック	即座に凍結審査
High	20～49	ログイン時の追加認証（2FA強制）	48時間以内に審査
Medium	5～19	監視強化（ログ記録頻度UP）	月次レビュー時に確認
Low	5未満	なし	なし

第3章 アカウント凍結基準

3.1 即座に凍結すべきケース

以下のいずれかに該当する場合、システム管理者は即座にアカウントを凍結する。

1. リスクスコアが50以上（Criticalレベル）
2. 同一IPから10分以内に100回以上のログイン試行
3. 不正なクレジットカードの使用が確認された場合
4. BOTによる大量購入が確認された場合（同一アカウントから1分以内に5件以上の注文）
5. 他ユーザーのアカウントへの不正アクセスが確認された場合

3.2 審査の上で凍結を判断するケース

以下の場合、セキュリティチーム内で審査を行い、凍結の要否を判断する。

1. リスクスコアが20～49（Highレベル）で、直近30日以内に正規の購入履歴がある
2. 海外IPからのアクセスが急増しているが、過去にも海外アクセス履歴がある
3. 顧客からの問い合わせで「アカウントが乗っ取られた」と申告があった場合

3.3 凍結してはならないケース

- ・ リスクスコアが20未満の顧客
- ・ 過去6ヶ月以内に3回以上の正規購入があり、かつリスクスコアが30未満の顧客
- ・ 凍結により重大な損害（LTV 10万円以上の顧客の永久離脱等）が見込まれる場合は、EC事業部長と協議の上で判断

第4章 凍結手順

4.1 凍結実施

1. セキュリティダッシュボードで対象アカウントのリスク情報を確認
2. アカウント管理コンソールにログイン
3. 対象アカウントのステータスを「凍結」に変更
4. 凍結理由を記録（必須）
5. 凍結通知メールを顧客に送信（テンプレート：「アカウント凍結のお知らせ」）

4.2 凍結時の注意事項

- ・凍結中のアカウントは、ログイン・購入・ポイント利用がすべて不可となる
 - ・進行中の配送は凍結の影響を受けない（配送は継続する）
 - ・凍結されたアカウントのデータは最低1年間保持する
-

第5章 凍結解除

5.1 解除申請プロセス

1. 顧客がカスタマーサポートに解除申請
2. 本人確認（身分証明書 + 登録メールアドレスからの申請）
3. セキュリティチームが不正利用の原因を調査
4. 原因が解消されたことを確認（パスワード変更、2FA設定等）
5. セキュリティチームリーダーの承認で解除

5.2 解除の条件

- ・凍結原因となった不正行為が、アカウント所有者本人によるものでないことが確認された場合
- ・アカウント乗っ取りの場合: パスワード変更 + 2FA有効化が完了していること
- ・BOTによる自動購入の場合: 解除不可。新規アカウントの作成を案内

5.3 解除後のフォローアップ

- ・解除後30日間は監視強化（Medium以上の扱い）
 - ・解除後7日以内にフォローアップメールを送信
 - ・再度同様の不正が検知された場合は、即座に再凍結
-

第6章 定期レビュー

6.1 月次レビュー

毎月第1営業日に、以下を確認する。

- ・新規凍結アカウント数
- ・凍結解除数
- ・リスクスコアHighの未審査アカウント

- ・BOT検知精度の確認（誤検知率）

6.2 四半期レビュー

- ・リスクスコアの重み付けの妥当性を検証
- ・凍結基準の見直し（市場の不正手口の変化に対応）
- ・セキュリティチームと顧客対応チームの合同レビュー

付録 BOTユーザーの特徴パターン

当社で過去に検知されたBOTユーザーの典型的な特徴:

特徴	詳細
登録日	同一日に大量のアカウントが作成される
都道府県	同一地域に集中（過去事例: 埼玉県）
行動パターン	add_to_cart → abandon のみを繰り返す。purchaseやviewがゼロ
対象商品	高額な電子機器に集中
アクセス時間帯	深夜帯（2:00～5:00）に集中
IPアドレス	同一サブネット（/24）内に集中

これらの特徴に複数該当するアカウントは、BOTの可能性が極めて高い。